Response to Craig's Review

GymAxis AI Platform - Answers to every concern raised
Prepared for the Managing Director, Pulse Fitness
20 April 2026

0 First - Craig is right to raise every point he raised

Before answering, please pass this on to Craig with our thanks. Every question in his note is exactly what a responsible IT manager should ask before connecting anything to Sage 200 after a previous breach. We welcome the scrutiny. Nothing goes near live Sage data until a proper technical review is signed off.

1 "We'd need Eventura and Kodedweb to complete the integration"

Fully agreed. The Sage 200 link cannot - and should not - be built without them.

- The platform today treats Sage 200 as a stub. No connection to Pulse's live Sage 200 exists. No data has ever flowed either way.
- The recommended path is exactly what Craig describes: Eventura provides the Sage Web API configuration, Kodedweb confirms the pattern matches Sage's integration guidelines, we implement to that spec.
- We will not activate the Sage 200 link until Eventura have signed off on the integration approach in writing.

Plain English: we have not plugged anything into Sage yet, and we will not plug it in without the people Craig trusts agreeing to the plan first.

2 "We need visibility of how the solution is built"

We can give Craig full visibility today. On request we will provide:

- A live, read-only walkthrough of the codebase (architecture, integration layer, error handling, logging).
- The complete Sicon Integration Specification (R260200c-aligned) - the document we followed to build the existing Sicon link.
- A one-page architecture diagram showing every external connection (Sicon, Stripe, Resend, future Sage 200).
- Access to the staging environment with a read-only engineer account so Craig can see how the platform behaves without risk to production data.

This is not a closed black box. It is a conventional React + FastAPI + MongoDB stack with a documented integration layer and 500+ automated tests that run on every code change.

3 "Stable Sage integration usually requires Sage developer coordination"

Agreed - and we plan to do exactly that. Our proposed sequence:

- Eventura provide the Sage 200 Web API endpoint, credentials, and Pulse-specific configuration.
- Kodedweb confirm the data model aligns with what Pulse already relies on in Sage.

- We build against Sage's OFFICIAL Sage 200 Web API - not scraping, not direct DB access, not a workaround. Sage's own recommended pattern.
- Every call to Sage is logged with a correlation ID, retries on transient failure, and raises a visible alert on repeat failure. Nothing happens silently.
- A pilot period on a non-production Sage 200 company before any live customer is connected.

Plain English: we use Sage's own rulebook, go through the front door they provide, and prove it works on a sandbox before it touches Pulse's real Sage company.

4 "Security - especially after the previous breach"

A full Platform Security Briefing is already available (signed, dated Feb 2026). The short version:

Transport	HTTPS / TLS 1.2+ on every request - the same encryption banks use. No plain-text traffic anywhere.
Passwords	Hashed with bcrypt. Even our engineers cannot read a user's password.
Sessions	Short-lived JWT tokens, automatic expiry, rate-limited logins (5 failed attempts = blocked).
Roles	Six-tier separation. Each role sees only what it needs.
Data isolation	Every query is filtered by organisation ID at the code level. Customer A cannot see Customer B's data.
Audit log	Every action Pulse internal staff take - who, what, when. Immutable.
Sicon credentials	Server-side only, never sent to the browser, never visible to the customer.
Payment data	Not stored at all. Card numbers go directly to Stripe (PCI-DSS Level 1). We see only a reference.
GDPR erasure	Archived organisations permanently deleted after 365 days with 7-day advance email notice.

On the previous breach: the concerns were database access, credential hygiene, and data partitioning. Those are the three areas we built the platform around from day one.

5 "I can't validate credential management without review access"

Craig is the right person to review it - we want him to. Proposed review package:

- A 90-minute technical walkthrough: credential storage, environment configuration, encryption at rest, key rotation policy.
- Read-only staging access (real credentials themselves redacted).
- A written response to any SIG-Lite or CAIQ-style security questionnaire Craig wants to send.
- Independent third-party penetration test before go-live with live Sage 200 data. Full report shared with Pulse.

If after all of that Craig is not comfortable, the Sage 200 link stays off. Non-negotiable.

6 "This may be a standalone product, not built specifically for Pulse"

Fair observation - worth being honest about.

- Pulse's data is entirely isolated from every other customer. Not just logically - physically partitioned by organisation ID on every read. Multi-tenancy is cost-efficient; it is NOT a

data-sharing compromise.

- Pulse-specific needs drive the roadmap: the Service Desk role, the Sicon migration pipeline, the Head-Office grouping for customer imports, the Pulse Lite / Pulse Pro tiers - all built at Pulse's request.

Three ownership models are available - happy to discuss any of them:

- 1. Shared platform, Pulse as a customer (current). Lowest cost, fastest features, shared R&D benefit.
- 2. White-label instance. Dedicated deployment, Pulse branding, Pulse's own database. Same codebase, separate infrastructure.
- 3. Source-code licence. Pulse owns the code outright, runs it internally with Craig's team. Highest cost, fullest control.

Plain English: the platform is shared for good economic reasons, but Pulse's DATA is not shared with anyone, and if the Director wants Pulse to own the software outright, that option is on the table.

7 "Rapidly-built, AI-assisted solutions can be hard to maintain"

Valid concern. Here is what we have put in place to prevent it:

- 500+ automated tests run on every code change. A change that breaks an existing feature fails immediately and cannot be shipped.
- Strict code-complexity gate - every function limited to cyclomatic complexity <= 10 (industry-standard 'simple' range). Over-complex code is blocked at commit time. This is stronger discipline than most hand-written systems.
- Structured logging everywhere - every API call, every integration call, every background job writes a structured log with timestamps and correlation IDs.
- Error handling is explicit, not implicit. Every external call has a timeout, retry policy, and fallback. The Sicon retry queue with exponential back-off is a concrete example - a Sicon outage never loses data.
- Modular architecture - 130+ files organised into clear domains (routes, utils, integrations, scripts, tests). No monolithic files.
- Pre-commit hooks enforce linting, complexity, secret-scanning, and formatting before any change reaches the repository.
- Documented specs precede code. The Sicon spec alone is 400+ written lines.

Plain English: AI helped us build faster. It did not build carelessly. The tests, complexity limits, and logging are the proof - Craig can inspect them.

8 "Who takes responsibility for ongoing support?"

Proposed support model, written down:

- Business-hours support (09:00-17:30 Mon-Fri) - email + ticket portal. 4-hour response, same-day triage.
- Critical incident (Sage link down, data integrity suspected) - pager escalation, 1-hour response, rolling status updates.
- Monthly operational review with Craig or his delegate - recent incidents, upcoming releases, security posture, roadmap input.

- Quarterly security review with written summary to the Director.
- Named engineering contact - one human being, not a support queue, owns the Pulse relationship end-to-end.

Written into an SLA before any production go-live. If Pulse prefers internal support (model 3 above), we provide a 60-day transition with full knowledge transfer.

9 "Craig hasn't been involved in development so far"

That is our gap to close, not his to justify. Correcting that now:

- Craig is invited to the technical review described in sections 2 and 5.
- Craig has editorial rights on the Sage 200 integration spec before any code is written against live Sage.
- Craig receives staging environment read-only access this week if he wants it.
- Craig's feedback on the CRM element, whenever he has capacity, is welcome - even as a 30-minute written note. We will not ask him to take on Pulse-specific CRM development work.

Craig has said he prefers to focus on Pulse-specific solutions. Completely reasonable. Our relationship with Pulse does not depend on Craig doing development work on our platform - it depends on him being comfortable that the platform is safe to plug into Pulse's Sage 200. That is a review activity, not a development activity.

10 Proposed path forward - step by step

1. Architecture walkthrough	Us + Craig. Within 2 weeks of Director sign-off.
2. Staging read-only access	Provided same day as step 1.
3. Security questionnaire	We answer Craig's list inside 5 working days.
4. Sage 200 integration spec	Us + Eventura + Craig. Within 4 weeks.
5. Independent pen-test	Third-party. Before production go-live.
6. Pilot on non-production Sage	Us + Eventura. 4-6 weeks after step 4.
7. Production go-live	Only if steps 1-6 pass. Quality-gated, no fixed date.

No step is skipped. Nothing reaches production until every step above has passed and Craig has signed off.

11 In one paragraph, for the Managing Director

The platform is genuinely safe to plug into Sage 200, but we are not asking the Director to take that on trust. We are asking for a formal technical review with Craig, Eventura, and Kodedweb before any live data moves. We have built the foundations - encryption, isolation, audit logging, testing, complexity controls - to a higher standard than a typical hand-written system, and we are happy to prove it line by line. If at any point during that review Craig is not satisfied, the Sage link stays off. Pulse retains full control over whether this goes to production, and on what terms. Craig's caution is not a blocker - it is exactly what a mature IT function should do. We welcome it.

Document version 1.0 - prepared 20 April 2026 for the Managing Director of Pulse Fitness. Available for walkthrough by videocall, on-site, or written Q&A - whichever the Director and Craig prefer. For internal use only.